



Lección 04

AAA local y política de firewall

Diseño, implementación y validación de controles de acceso.
Guía de estudio paso a paso para sistemas Linux (UFW y AAA).

Cuenta compartida

SSH expuesto

**Falta de revisión
de logs**



Cuatro personas utilizan la misma cuenta administrativa y la misma contraseña.
Impacto: Es imposible saber quién hizo qué (atribución nula).

El puerto de administración responde a toda la red.
Impacto: Aumenta la superficie de ataque; cualquier equipo infectado puede intentar entrar.

Nadie lee los registros.
Impacto: Un ataque o un error operativo puede ocurrir sin que nadie lo note hasta que el servicio colapse.

Conclusión: Necesitamos controles para identificar usuarios únicos, limitar sus permisos y restringir desde dónde pueden acceder.

Vocabulario base: De la persona al privilegio



Identidad

Quién es la persona o servicio
(Ej. Camila)

Cuenta

El registro del sistema para esa identidad
(Ej. soporte01)

Credencial

Lo que demuestra la identidad
(Ej. Contraseña o Clave SSH)

Sesión

El contexto temporal tras ingresar
(Ej. Login SSH de 10:00 a 10:15)

Rol

Conjunto de permisos asignados a una función
(Ej. Soporte técnico)

Idea Clave: ¡Una contraseña correcta demuestra una credencial, no una intención ni un permiso! Nunca compartas cuentas.

El modelo AAA: El flujo de una sesión segura



Nota Crítica: Una contraseña correcta (Authentication) **NO** implica **autorización**. Un usuario puede entrar al sistema y ser bloqueado al intentar modificar la red.

Asignación de roles y menor privilegio

Menor privilegio: cada rol recibe únicamente los permisos necesarios para cumplir su función.

admin01 (Rol: admin-red):
Administra la configuración de red.

soporte01 (Rol: soporte):
Ejecuta tareas operativas acotadas.

auditor01 (Rol: auditor):
Consulta registros sin modificar nada.

Rol	SSH	Consultar SSH	Consultar firewall	Modificar firewall	Logs SSH
admin01	✓	—	✓	✓	—
soporte01	✓	✓	✗	✗	—
auditor01	✓	—	✓	✗	✓

¿Dónde viven las identidades?

Local vs Centralizado



AAA Local (Linux)



- **Mecanismo:** Cuentas locales del sistema; credenciales protegidas localmente y permisos definidos mediante grupos y sudoers.
- **Ventaja:** Simple, funciona sin conexión a otras redes.
- **Límite:** Difícil de escalar. Revocar un acceso en 50 servidores requiere entrar a cada uno.



AAA Centralized (RADIUS / TACACS+)



- **Mecanismo:** Un servidor externo valida el acceso de toda la red.
 - **RADIUS:** usado ampliamente para acceso a red.
 - **TACACS+:** frecuente en administración de dispositivos y control detallado de acciones.
- **Ventaja:** Un solo punto de gestión; trazabilidad unificada.
- **Límite:** Requiere conectividad. Si el servicio AAA centralizado queda inaccesible, la autenticación puede fallar si no existe redundancia o un mecanismo local de emergencia.

Foco del Laboratorio: Aplicaremos AAA Local para dominar la base conceptual.

Accounting: Reconstruyendo la historia



Las 6 preguntas de un buen registro:

1. ¿Quién?
2. ¿Qué?
3. ¿Sobre qué?
4. ¿Cuándo?
5. ¿Desde dónde?
6. ¿Resultado?

Qué DEBE registrarse:

- Inicios de sesión (éxitos y fallos).
- Uso de comandos privilegiados (sudo).
- Bloqueos y rechazos del firewall.



Qué NUNCA debe registrarse (Riesgo de Seguridad):

- Contraseñas en texto claro.
- Claves privadas o tokens de sesión.

Regla de Oro: Generar logs sin que nadie los consulte, o sin retención definida, no es un control efectivo.

El Firewall: Función, Políticas y Reglas

- **Un firewall no corrige vulnerabilidades**, solo filtra tráfico según reglas exactas.

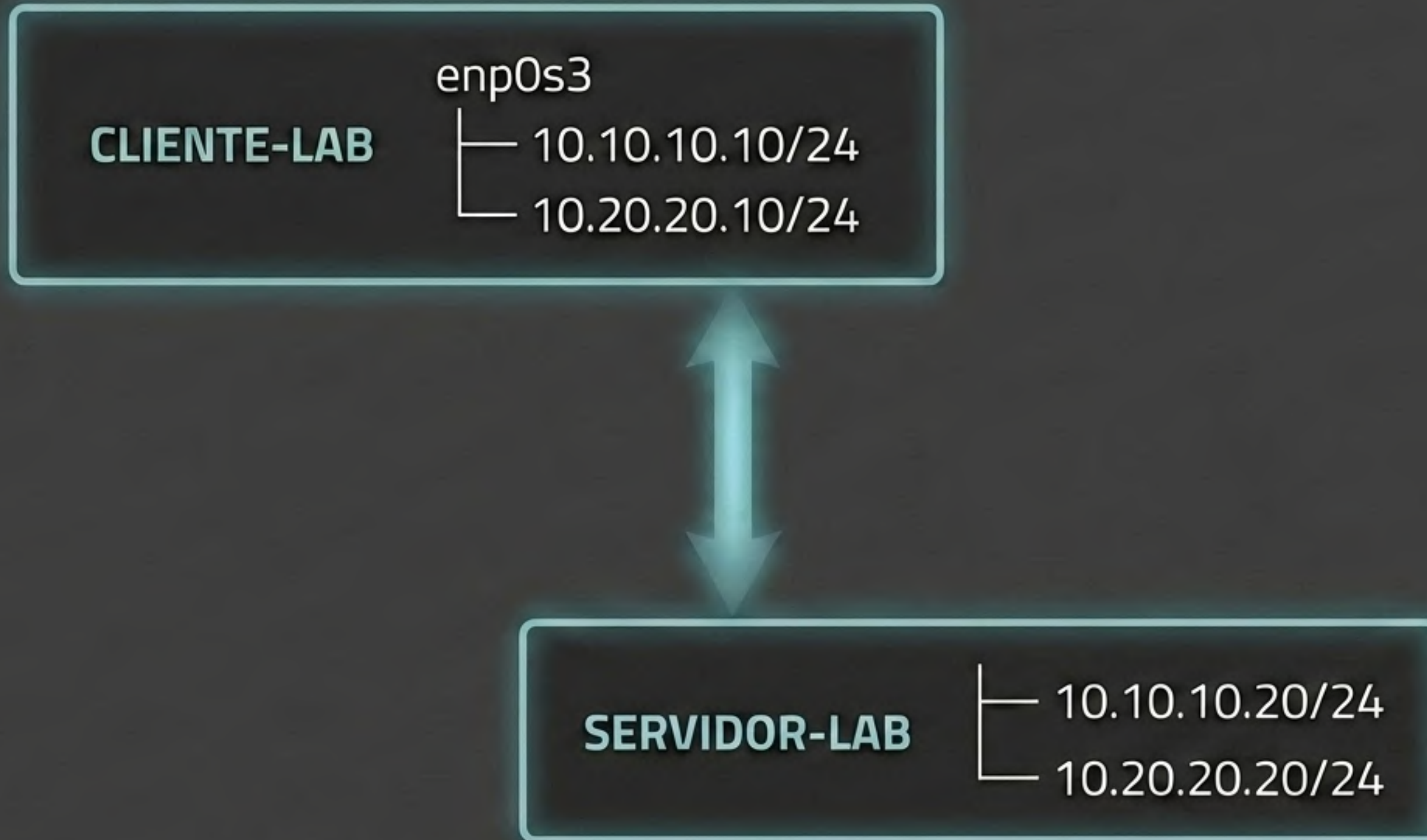
- **Política vs. Regla**
La política es la intención humana ('Solo admin accede'). La regla es la técnica que la ejecuta.

- **Una regla puede considerar:**
Origen · Destino · Protocolo · Puerto/servicio · Acción



- **Orden de reglas**
En muchas plataformas las reglas se evalúan en orden y una regla amplia puede ocultar otra más específica. El comportamiento debe verificarse según la plataforma.
- **Estado (Stateful)**
El firewall recuerda las conexiones establecidas, permitiendo automáticamente el tráfico de retorno.
- **Denegación por defecto**
Se rechaza todo el tráfico entrante no especificado. Solo abrimos lo necesario.

Topología del Escenario (Red Aislada)



SSH administrativo permitido únicamente desde 10.10.10.0/24.

Línea Base: Medir antes de cortar

Nunca modifiques un sistema sin verificar su estado actual y tener un plan de escape.

```
sha256sum -c manifest_entrega.sha256
```



verificar que todos indiquen OK

```
ip -br addr
```



ambas IP presentes;

```
ping -c 2 10.10.10.20  
ping -c 2 10.20.20.20
```



ambos destinos responden;

```
ip route
```



no existe ruta default;

```
sudo ufw status
```



UFW está inactive.



Reversión obligatoria (El Salvavidas): Antes de tocar el firewall, confirma que existe una vía de reversión, como la instantánea LAB04-INICIAL, y mantén acceso por consola. Un error en las reglas puede dejarte sin acceso remoto al servidor.

Implementación: Aplicando la política en UFW

```
sudo ufw default deny incoming      # Rechaza todo lo entrante por defecto
sudo ufw default allow outgoing     # Permite que el servidor responda
sudo ufw allow from 10.10.10.0/24 to any port 22 proto tcp # SSH desde 10.10.10.0/24
sudo ufw allow 443/tcp              # HTTPS del portal de carga
sudo ufw logging low                # Registra tráfico bloqueado por UFW
sudo ufw show added                 # REVISIÓN: ¿Están bien escritas?
sudo ufw enable                     # Actívalo desde consola, no desde una sesión SSH.
sudo ufw status numbered            # Muestra el estado y orden final
```

Validar AAA: Probando el menor privilegio

Autenticación exitosa $\neq$ autorización ilimitada.

Prueba con cuenta **admin01**

```
ssh admin01@10.10.10.20 →  
(Autenticación exitosa)
```

```
sudo -l → (Verifica autorizaciones de  
sudo para este rol)
```

Resultado esperado: /usr/sbin/ufw

Está autorizado a administrar UFW, pero no obtiene privilegios generales.

Prueba con cuenta **soporte01**

```
sudo ufw status verbose
```

DENEGADO. Soporte no está autorizado a tocar el Firewall.

```
sudo systemctl status ssh --no-pager
```

PERMITIDO. Soporte sí puede verificar el estado de los servicios.

Validar UFW: Pruebas positivas y negativas

Prueba Positiva

Origen Permitido (Red 10.10)

```
ssh  
admin01@10.10.10.20
```

Resultado: Pide contraseña. El firewall dejó pasar la conexión.

Prueba Negativa

Origen Denegado (Red 10.20)

```
ssh -o ConnectTimeout=10  
admin01@10.20.20.20
```

Resultado: Falla por Timeout (tiempo agotado).

Límite de la prueba (Advertencia): Un timeout solo indica que el paquete no llegó o no volvió (podría ser un cable roto o fallo de red). Para afirmar científicamente que "el firewall lo bloqueó", necesitamos evidencia empírica en los logs.

Accounting: Confirmar el resultado con evidencia

Evidencia de Autenticación (AAA)

```
sudo journalctl -u ssh --since -20min | tail -20  
Buscamos: Accepted password for admin01 from 10.10.10.10
```

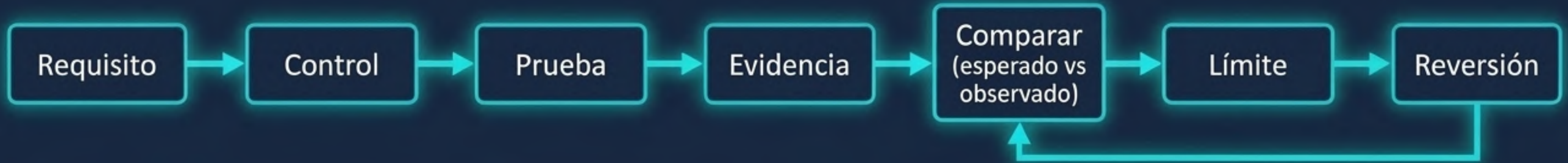
Demuestra: Autenticación **exitosa** (credencial validada desde IP origen).

Evidencia del Firewall (UFW)

```
sudo journalctl -k --since -20min | grep BLOCK | tail -5  
Buscamos: [UFW BLOCK] ... SRC=10.20.20.10 DST=10.20.20.20 .. DPT=22
```

SRC=10.20.20.10 → origen bloqueado
DPT=22 → puerto SSH

El ciclo de vida de un control de seguridad



Diferencia Crítica:

Un control no puede considerarse validado solo porque la configuración fue aceptada: debe contrastarse con evidencia, reconocer sus límites y de una vía de reversión.



Errores Frecuentes a Evitar:

- ⚠ Probar únicamente los casos permitidos.
- ⚠ Confundir una configuración aceptada con un control validado.
- ⚠ Concluir que el sistema es seguro a partir de unas pocas pruebas.
- ⚠ Aplicar cambios sin una vía de reversión.

Reflexión Final:

Un control no puede considerarse validado solo porque la configuración fue aceptada: debe probarse, contrastarse con evidencia, reconocer sus límites y disponer de una vía de reversión.